

Trường Đại Học Công Nghệ Thông Tin

NHẬP MÔN BẢO ĐẢM VÀ AN NINH THÔNG TIN

ThS. Tô Nguyễn Nhật Quang

Đánh giá môn học

1. Quá trình: 20%

- Học 7-8 buổi Lý thuyết.
- Mỗi buổi sẽ có bài tập (Quá trình) ở cuối buổi học

2. Thực hành: 30%

- Học 2-3 buổi Thực hành
- Hình thức 2

3. Thi cuối kỳ hoặc làm đồ án môn học: 50%

NỘI DUNG MÔN HỌC

1. Tổng quan môn học
2. Các kỹ thuật mã hoá
 - A. Mã hoá cổ điển và mã hoá hiện đại
 - B. Chứng thực dữ liệu
3. Dò tìm lỗ hổng bảo mật thông tin
 - A. Thăm dò
 - B. Quét mạng
4. Các nguy cơ bảo mật trên hệ thống
5. Mã độc và kỹ thuật phân tích mã độc
6. Bảo mật ứng dụng Web
7. Nguy cơ bảo mật ứng dụng di động
8. Tường lửa, hệ thống phát hiện và ngăn ngừa xâm nhập
9. Quản lý rủi ro an ninh thông tin
10. Một số xu thế an ninh thông tin hiện đại

BÀI 1

TỔNG QUAN



Nội dung

1. Một số khái niệm
2. Một số kỹ thuật tấn công phổ biến và cơ chế phòng thủ
3. Lý lịch của những kẻ tấn công
4. Mô hình bảo mật cơ bản
5. Bài tập

1. Một số khái niệm

Ngành **An ninh thông tin** (Information Security) bao gồm nhiều mảng kiến thức và kỹ năng nhằm **bảo vệ thông tin, hệ thống và dữ liệu** khỏi các mối đe dọa như truy cập trái phép, tấn công mạng, hay phá hoại dữ liệu.

1. Một số khái niệm

Dưới đây là **các nội dung chính** thường có trong lĩnh vực này:

1. Cơ sở về An toàn và An ninh thông tin

- Khái niệm, nguyên lý và mô hình bảo mật (tam giác CIA: Confidentiality – Integrity – Availability).
- Các loại mối đe dọa và tấn công mạng.
- Các chính sách, tiêu chuẩn và quy trình bảo mật (ISO/IEC 27001, NIST, v.v.).
- Quản lý rủi ro và đánh giá an ninh thông tin.

2. Mật mã học (Cryptography)

- Nguyên lý và thuật toán mã hóa: đối xứng (AES, DES), bất đối xứng (RSA, ECC).
- Chữ ký số, chứng thực, hạ tầng khóa công khai (PKI).
- Giao thức bảo mật trong truyền thông (SSL/TLS, HTTPS, SSH).
- Ứng dụng của mật mã trong blockchain, VPN, chữ ký điện tử.

1. Một số khái niệm

3. An ninh mạng (Network Security)

- Kiến trúc và mô hình mạng (OSI, TCP/IP).
- Bảo mật tầng mạng, tầng vận chuyển và ứng dụng.
- Cấu hình tường lửa (Firewall), IDS/IPS, VPN, NAT, VLAN.
- Phòng chống tấn công DoS/DDoS, sniffing, spoofing, man-in-the-middle, v.v.

4. An ninh hệ thống và phần mềm

- Bảo mật hệ điều hành (Windows, Linux).
- Quản lý bản vá, phân quyền, giám sát nhật ký hệ thống.
- An ninh ứng dụng web (OWASP Top 10: SQL Injection, XSS, CSRF...).
- Kỹ thuật kiểm thử xâm nhập (Penetration Testing) và khai thác lỗ hổng (Vulnerability Assessment).

1. Một số khái niệm

5. Phân tích mã độc và ứng phó sự cố

- Các loại mã độc (virus, worm, trojan, ransomware, rootkit...).
- Kỹ thuật phân tích tĩnh, động, và đảo ngược (reverse engineering).
- Ứng phó và điều tra sự cố an ninh (Incident Response, Forensics).
- Sử dụng công cụ giám sát và sandbox (Wireshark, IDA Pro, Cuckoo, v.v.).

6. An toàn dữ liệu và điện toán đám mây

- Bảo vệ dữ liệu trong lưu trữ và truyền tải.
- Quản lý truy cập, sao lưu và khôi phục dữ liệu.
- An ninh trong môi trường cloud (AWS, Azure, GCP).
- Khái niệm Zero Trust, bảo mật container và DevSecOps.

1. Một số khái niệm

7. Chính sách, pháp luật và quản trị an ninh thông tin

- Luật an ninh mạng, luật bảo vệ dữ liệu cá nhân (GDPR, Nghị định 13/2023/NĐ-CP).
- Quản trị an toàn thông tin trong tổ chức.
- Đạo đức nghề nghiệp và trách nhiệm pháp lý trong an ninh mạng.
- Đánh giá và chứng nhận an toàn hệ thống thông tin.

8. Xu hướng và công nghệ mới

- AI và Machine Learning trong phát hiện tấn công mạng.
- Blockchain trong bảo mật dữ liệu và giao dịch.
- An ninh IoT, an ninh hệ thống SCADA/ICS.
- Quantum Cryptography (mật mã lượng tử).

1. Một số khái niệm

- Dưới đây là các nội dung chính thường có trong lĩnh vực này:

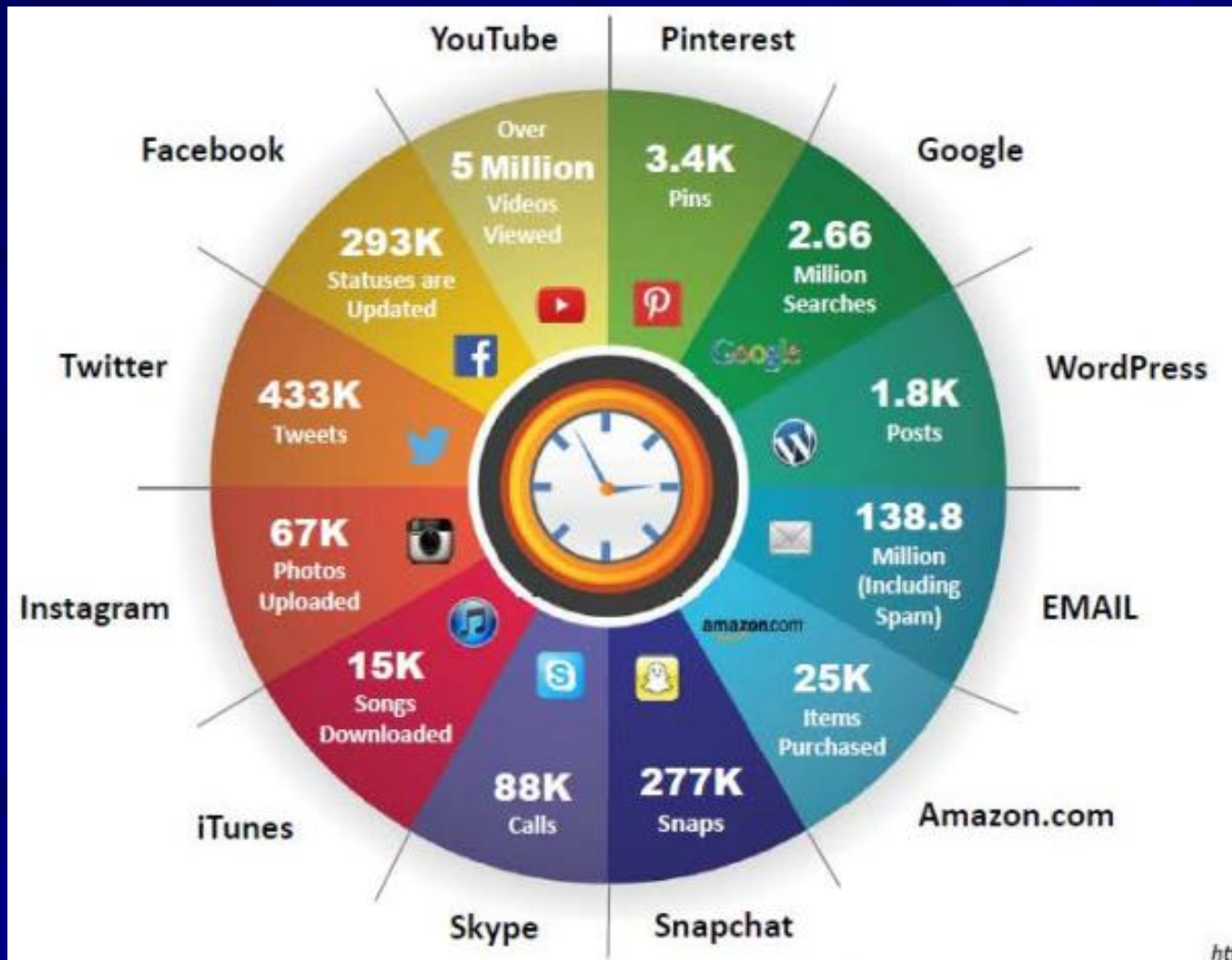


1. Một số khái niệm

- Dữ liệu là gì?
- Hai trạng thái của dữ liệu:
 - Transmission state
 - Storage state
- Bốn yêu cầu của dữ liệu:
 - Tính bí mật (Confidentiality)
 - Tính toàn vẹn (Integrity)
 - Tính không thể từ chối (Non-repudiation)
 - Tính sẵn sàng (Availability)

1. Một số khái niệm

Một số hoạt động online trên internet diễn ra mỗi 60 giây

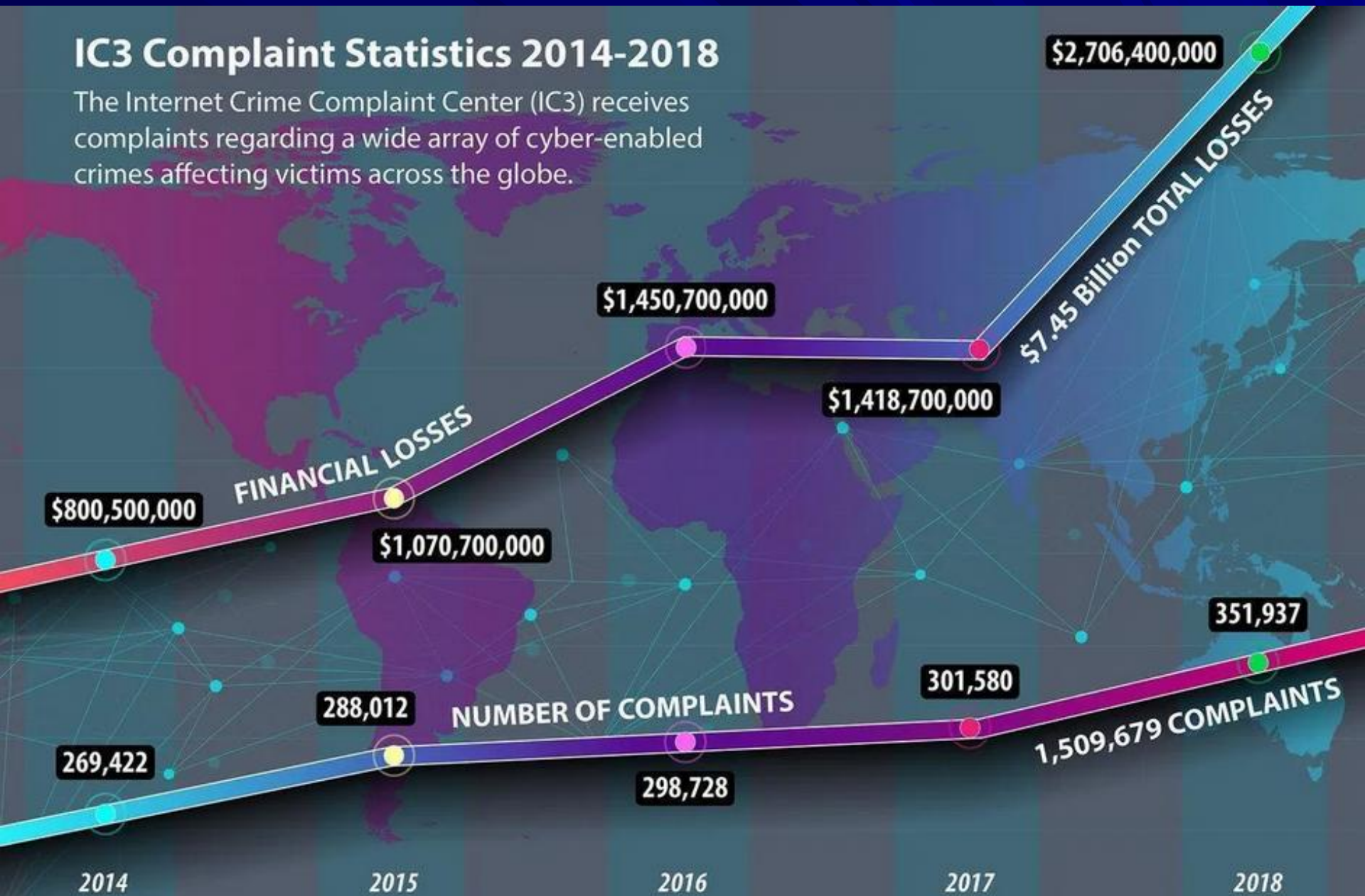


FBI's Internet Crime Complaint Center Received 467,361 complaints .

Báo cáo hàng năm của IC3

IC3 Complaint Statistics 2014-2018

The Internet Crime Complaint Center (IC3) receives complaints regarding a wide array of cyber-enabled crimes affecting victims across the globe.



Tỷ lệ nạn nhân theo nhóm tuổi

Highlights from the IC3's
2016 Internet Crime Report

\$1.33 Billion
Victim Losses in 2016



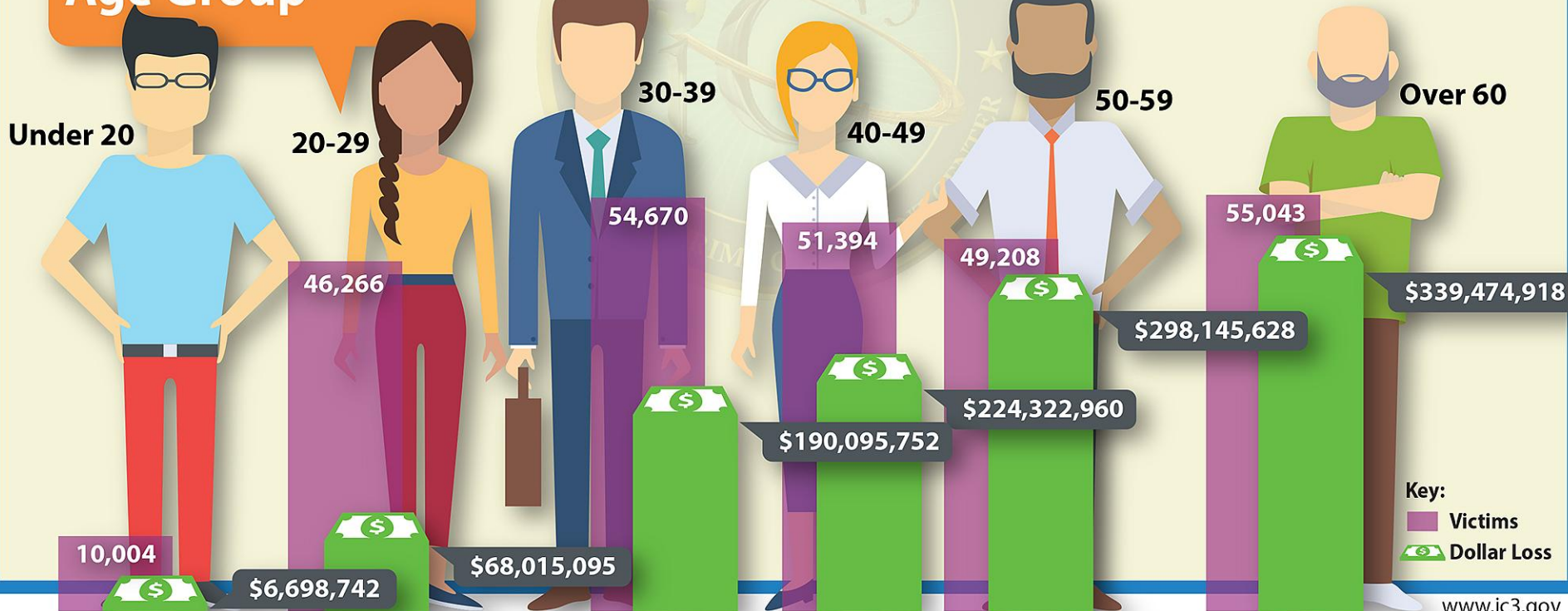
280,000

Average Number of Complaints
Reported to IC3 Each Year



3,762,358
Total Number
of Complaints
(2000-2016)

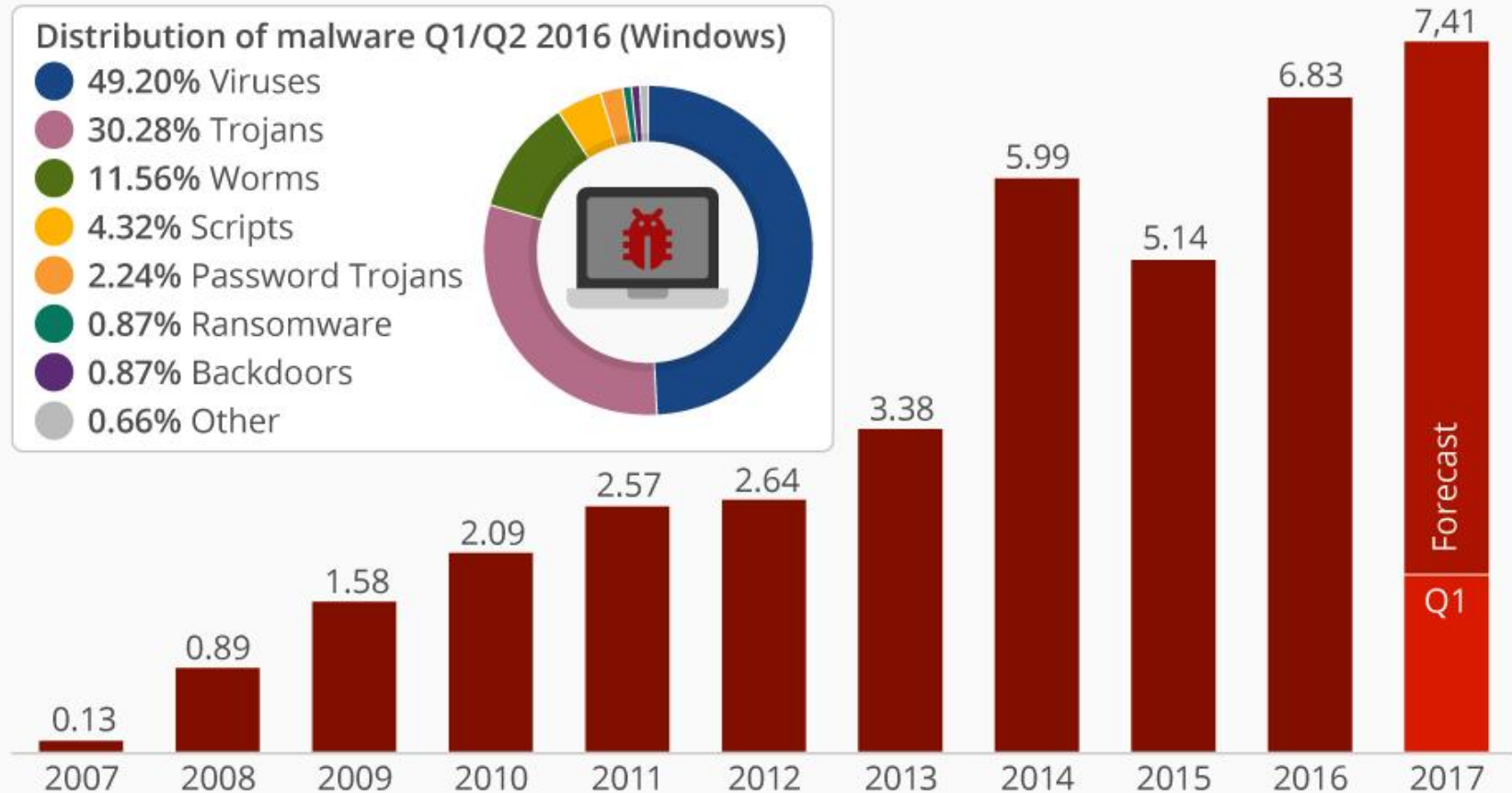
2016 Victims by Age Group



Số lượng và tỷ lệ mã độc

Viruses, Worms and Trojan Horses

Number of new malware specimen (in millions)



1. Một số khái niệm

Các thách thức



1. Một số khái niệm

Các mối nguy



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

Eavesdropping

Identity Spoofing

Snooping Attacks

Interception

Replay Attacks

Data Modification Attacks

Repudiation Attacks

DoS Attacks

DDoS Attacks

Password Guessing Attacks

Man-in-the-Middle Attacks

Back door Attacks

Spoofing Attacks

Compromised-Key Attacks

Application-Layer Attacks



Attacks on a System



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

1. *Eavesdropping*

- Nghe trộm là một phương pháp cũ nhưng hiệu quả.
- Sử dụng một thiết bị mạng (router, card mạng...) và một chương trình ứng dụng (Tcpdump, Ethereal, Wireshark...) để giám sát lưu lượng mạng, bắt các gói tin đi qua thiết bị này.
- Thực hiện dễ dàng hơn với mạng không dây.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

1. *Eavesdropping*

- Không có cách nào ngăn chặn việc nghe trộm trong một mạng công cộng.
- Để chống lại việc nghe trộm, cách tốt nhất là mã hoá dữ liệu trước khi truyền chúng trên mạng.
 - Plaintext: văn bản gốc
 - Cyphertext: chuỗi mật mã
 - Key: khoá mã hoá hoặc giải mã

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

2. *Cryptanalysis*

- Là nghệ thuật tìm kiếm thông tin hữu ích từ dữ liệu đã mã hoá mà không cần biết khoá giải mã.
- Ví dụ: phân tích cấu trúc thống kê của các ký tự trong phương pháp mã hoá bằng tần suất.
- Phương pháp này thường sử dụng các công cụ toán học và máy tính có hiệu suất cao.
- Cách chống lại phá mã:
 - Sử dụng những giải thuật mã hoá không thể hiện cấu trúc thống kê trong chuỗi mật mã.
 - Khoá có độ dài lớn để chống Brute-force attacks.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

- Cơ chế chứng thực được sử dụng rộng rãi nhất là dùng username và password.
- Các phương pháp thông dụng bao gồm:
 - Guessing
 - Social engineering
 - Dictionary
 - Password sniffing

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

- Guessing: hiệu quả đối với các mật khẩu ngắn hoặc người dùng quên đổi mật khẩu ngầm định.

10 mật khẩu phổ biến nhất trên internet (theo PC Magazine):

- | | |
|-------------|-------------------------------|
| 1. Password | 2. 123456 |
| 3. qwerty | 4. abc123 |
| 5. letmein | 6. monkey |
| 7. myspace1 | 8. password1 |
| 9. blink182 | 10. the user's own first name |

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

- Social engineering: là phương pháp sử dụng các kỹ năng xã hội để ăn cắp thông tin mật của người khác.
 - Mạo danh (Impersonate)
 - Lừa đảo (Physing) qua email, websites...
 - Thu thập thông tin từ giấy tờ bị loại bỏ
 - Tạo trang web đăng nhập giả...

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

■ Dictionary Attacks:

- Chỉ những mật khẩu đã được mã hoá mới được lưu trên hệ thống máy tính.
- Hệ điều hành Windows NT/XP: tên user và mật khẩu của user đã được mã hoá được lưu trong registry của hệ thống với tên file là SAM.
- Dictionary attacks: duyệt tìm từ một từ điển (thu được từ các file SAM...) các username và password đã được mã hoá.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

■ Password Sniffing:

- Là một phần mềm dùng để bắt các thông tin đăng nhập từ xa như username và password đối với các ứng dụng mạng phổ biến như Telnet, FTP, SMTP, POP3.
- Để gây khó khăn cho việc Password Sniffing, có thể dùng những chương trình đặc biệt (như SSH trong HTTPS...) để mã hoá tất cả các thông điệp truyền.
- Cain & Abel là một công cụ khôi phục mật khẩu trong hệ điều hành Microsoft và cũng là một công cụ password sniffing có thể bắt và phá mã các password đã được mã hoá sử dụng từ điển hoặc brute-force. Có thể download công cụ này tại <http://www.oxid.it/cain.html>.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

- Một số phương pháp chứng minh danh tính người dùng đang được sử dụng:
 - Sử dụng mật khẩu bí mật (secret passwords): phổ biến nhất. Sử dụng tên người dùng và mật khẩu của người dùng.
 - Sử dụng sinh trắc học (biometrics): sử dụng các tính năng độc đáo của sinh học như vân tay, võng mạc... nhờ việc kết nối các thiết bị sinh trắc học (khá đắt tiền, chỉ dùng tại những nơi yêu cầu bảo mật ở mức độ cao) vào máy tính như máy đọc dấu vân tay, máy quét võng mạc...
 - Sử dụng chứng thực (authenticating items): dùng một số giao thức xác thực như Kerberos...

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

- Một số quy tắc bảo vệ mật khẩu:
 - Sử dụng mật khẩu dài kết hợp giữa chữ thường, chữ hoa, số và các ký tự đặc biệt như \$ # & %. Không dùng các từ có trong từ điển, các tên và mật khẩu thông dụng.
-> gây khó khăn cho việc đoán mật khẩu (guessing attacks) và tấn công sử dụng từ điển (dictionary attacks).
 - Không tiết lộ mật khẩu với những người không có thẩm quyền hoặc qua điện thoại, thư điện tử... -> chống lại social engineering.
 - Thay đổi mật khẩu định kỳ và không sử dụng trở lại những mật khẩu cũ để chống lại những cuộc tấn công từ điển hoặc mật khẩu cũ đã được nhận diện.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

3. *Password Pilfering*

- Một số quy tắc bảo vệ mật khẩu:
 - Không sử dụng cùng một mật khẩu cho các tài khoản khác nhau nhằm đảm bảo các tài khoản khác vẫn an toàn khi mật khẩu của một tài khoản bị lộ.
 - Không sử dụng những phần mềm đăng nhập từ xa mà không có cơ chế mã hoá mật khẩu và một số thông tin quan trọng khác.
 - Huỷ hoàn toàn các tài liệu có lưu các thông tin quan trọng.
 - Tránh nhập các thông tin trong các cửa sổ popup.
 - Không click vào các liên kết trong các email khả nghi.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

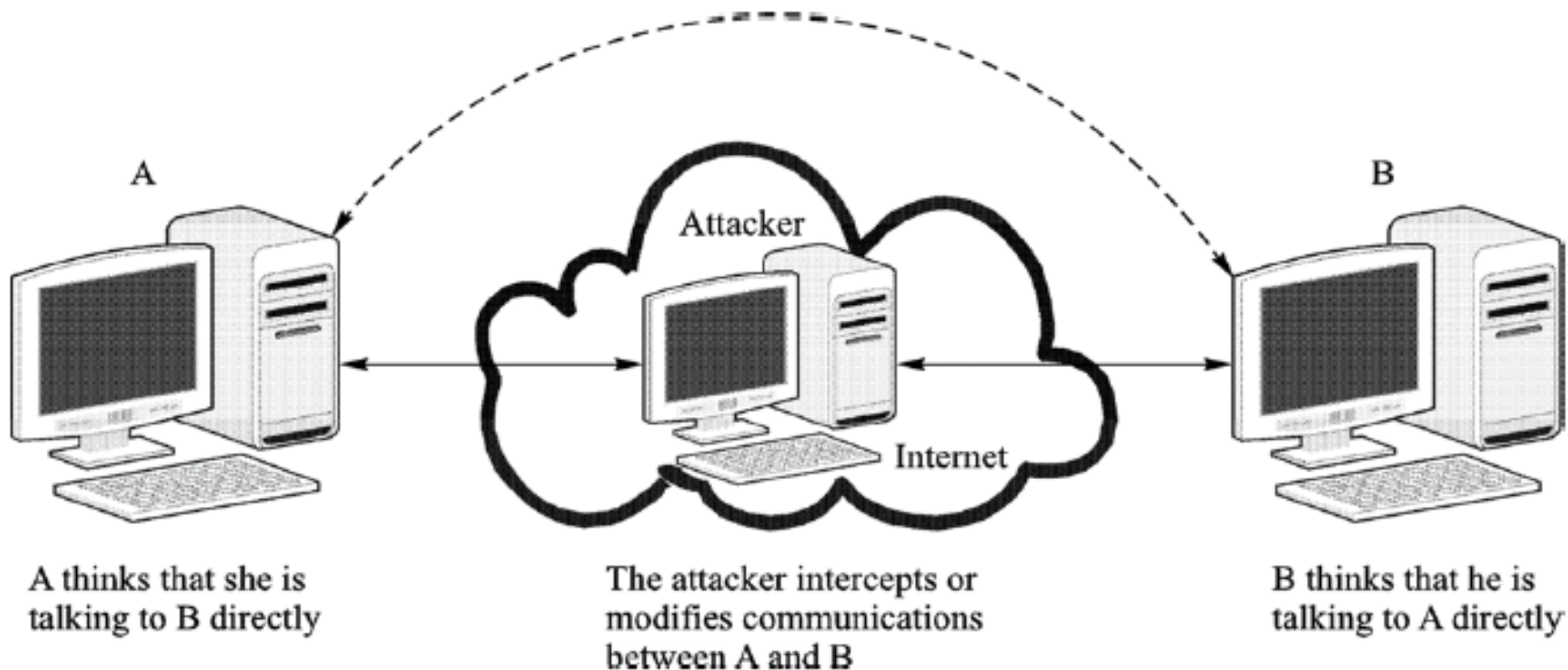
4. *Identity Spoofing*

- Là phương pháp tấn công cho phép kẻ tấn công mạo nhận nạn nhân mà không cần sử dụng mật khẩu của nạn nhân.
- Các phương pháp phổ biến bao gồm:
 - Man-in-the-middle attacks
 - Message replays attacks
 - Network spoofing attacks

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

4. *Identity Spoofing*

- Man-in-the-middle attacks



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

4. *Identity Spoofing*

■ Message replays:

- Trong một số giao thức xác thực, sau khi người dùng A chứng thực mình với hệ thống là một người dùng hợp pháp, A sẽ được cấp một chứng thực (giấy phép) thông qua. Với giấy phép này, A sẽ nhận được những dịch vụ cung cấp bởi hệ thống. Giấy phép này đã được mã hóa và không thể sửa đổi.
- Tuy nhiên, những kẻ tấn công có thể ngăn chặn nó, giữ một bản sao, và sử dụng nó sau này để mạo nhận (đóng vai) người dùng A để có được các dịch vụ từ hệ thống.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

4. *Identity Spoofing*

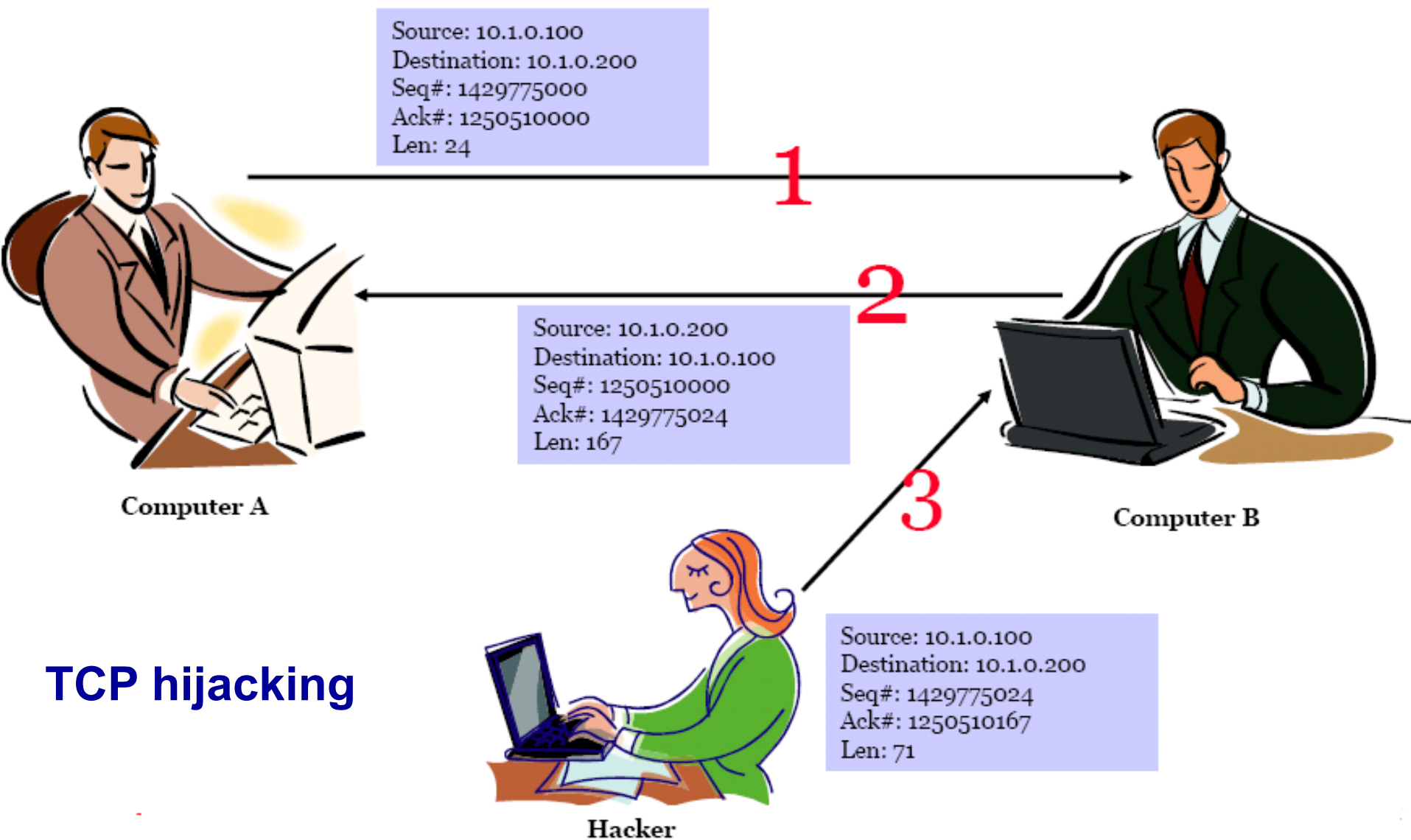
- Network Spoofing: IP Spoofing là một trong những kỹ thuật lừa gạt chính trên mạng. Bao gồm:
 - SYN flooding: Trong một cuộc tấn công SYN flooding, kẻ tấn công lấp đầy bộ đệm TCP của máy tính mục tiêu với một khối lượng lớn các gói SYN, làm cho máy tính mục tiêu không thể thiết lập các thông tin liên lạc với các máy tính khác. Khi điều này xảy ra, các máy tính mục tiêu được gọi là một máy tính câm.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

4. *Identity Spoofing*

- Network Spoofing: là một trong những kỹ thuật lừa gạt chính trên mạng. Bao gồm:
 - TCP hijacking:
 - Là một kỹ thuật sử dụng các gói tin giả mạo để chiếm đoạt một kết nối giữa máy tính nạn nhân và máy đích. Máy nạn nhân bị treo và hacker có thể truyền thông với máy đích như hacker chính là nạn nhân.
 - Để ngăn chặn TCP hijacking, có thể sử dụng phần mềm như TCP Wrappers để kiểm tra địa chỉ IP tại tầng TCP (tầng Transport).

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

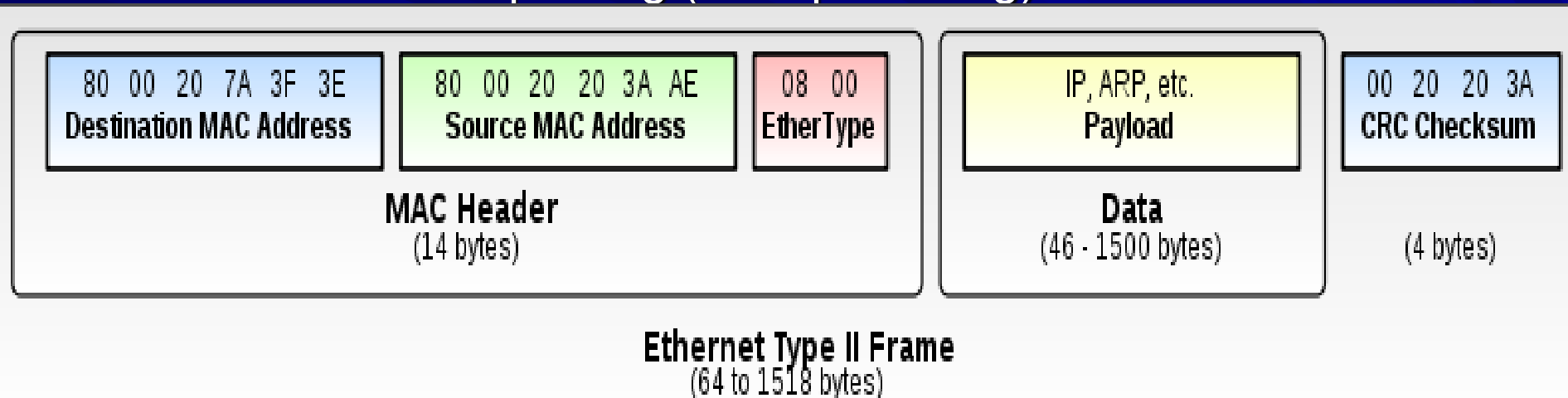
4. *Identity Spoofing*

- Network Spoofing: IP Spoofing là một trong những kỹ thuật lừa gạt chính trên mạng. Bao gồm:
 - ARP spoofing (ARP poisoning): ARP là một giao thức phân giải địa chỉ tại tầng liên kết có thể chuyển đổi địa chỉ IP đích trong header IP đến địa chỉ MAC của máy tính tại mạng đích.
 - Trong một cuộc tấn công giả mạo ARP, kẻ tấn công thay đổi địa chỉ MAC đích hợp pháp của một địa chỉ IP đến một địa chỉ MAC khác được lựa chọn bởi những kẻ tấn công.
 - Để ngăn chặn các cuộc tấn công ARP spoofing, cần phải tăng cường kiểm tra các tên miền, và chắc chắn rằng địa chỉ IP nguồn và địa chỉ IP đích trong một gói tin IP không được thay đổi trong khi truyền.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

4. Identity Spoofing

- Network Spoofing: IP Spoofing là một trong những kỹ thuật lừa gạt chính trên mạng. Bao gồm:
 - ARP spoofing (ARP poisoning):



Một frame Ethernet tiêu biểu. Một frame giả mạo có địa chỉ MAC nguồn sai có thể đánh lừa các thiết bị trên mạng.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

5. *Intrusion*

- Là kẻ xâm nhập bất hợp pháp vào một mạng với mục đích truy cập vào hệ thống máy tính của người khác, đánh cắp thông tin và tài nguyên máy tính hoặc bằng thông của nạn nhân.
- Cấu hình sơ hở, giao thức sai sót, tác dụng phụ của phần mềm đều có thể bị khai thác bởi kẻ xâm nhập.
- Mở các cổng UDP hoặc TCP không cần thiết là một sơ hở phổ biến. Đóng các cổng này lại có thể giảm thiểu việc xâm nhập.
- IP scan và Port scan là những công cụ hack phổ biến thuộc dạng này và cũng là những công cụ giúp người dùng kiểm tra được các lỗ hổng trong hệ thống.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

6. *Denial of Service Attacks*

- Mục tiêu của cuộc tấn công từ chối dịch vụ là ngăn chặn người dùng hợp pháp sử dụng những dịch vụ mà họ thường nhận được từ các máy chủ.
- Các cuộc tấn công như vậy thường buộc máy tính mục tiêu phải xử lý một số lượng lớn những thứ vô dụng, hy vọng máy tính này sẽ tiêu thụ tất cả các nguồn tài nguyên quan trọng.
- Một cuộc tấn công từ chối dịch vụ có thể được phát sinh từ một máy tính duy nhất (DoS), hoặc từ một nhóm các máy tính phân bố trên mạng Internet (DDoS).

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

6. *Denial of Service Attacks*

- DoS có các hình thức cơ bản sau:
 - Smurf
 - Buffer Overflow Attack
 - Ping of death
 - Teardrop
 - SYN Attack
- Công cụ để thực hiện tấn công DoS có thể là Jolt2, Bubonic.c, Land and LaTierra, Targa, Blast20, Nemesy, Panther2, Crazy Pinger, Some Trouble, UDP Flood, FSMax...

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

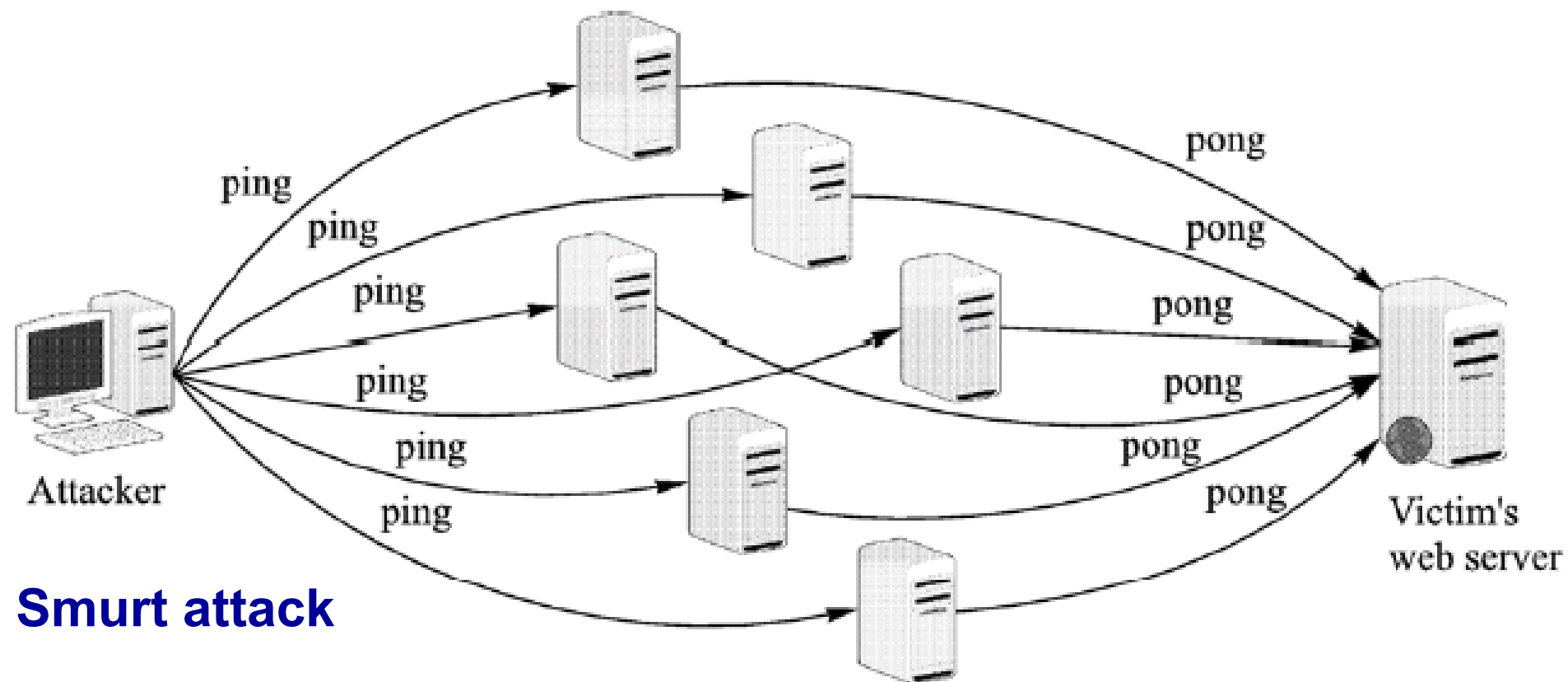
6. *Denial of Service Attacks*

- DoS: Smurf là một loại tấn công DoS điển hình. Máy của attacker sẽ gửi rất nhiều lệnh ping đến một số lượng lớn máy tính trong một thời gian ngắn trong đó địa chỉ IP nguồn của gói ICMP echo sẽ được thay thế bởi địa chỉ IP của nạn nhân. Các máy tính này sẽ trả lại các gói ICMP reply đến máy nạn nhân. Việc phải xử lý một số lượng quá lớn các gói ICMP reply trong một thời gian ngắn khiến tài nguyên của máy sẽ bị cạn kiệt.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

6. Denial of Service Attacks

– DoS:

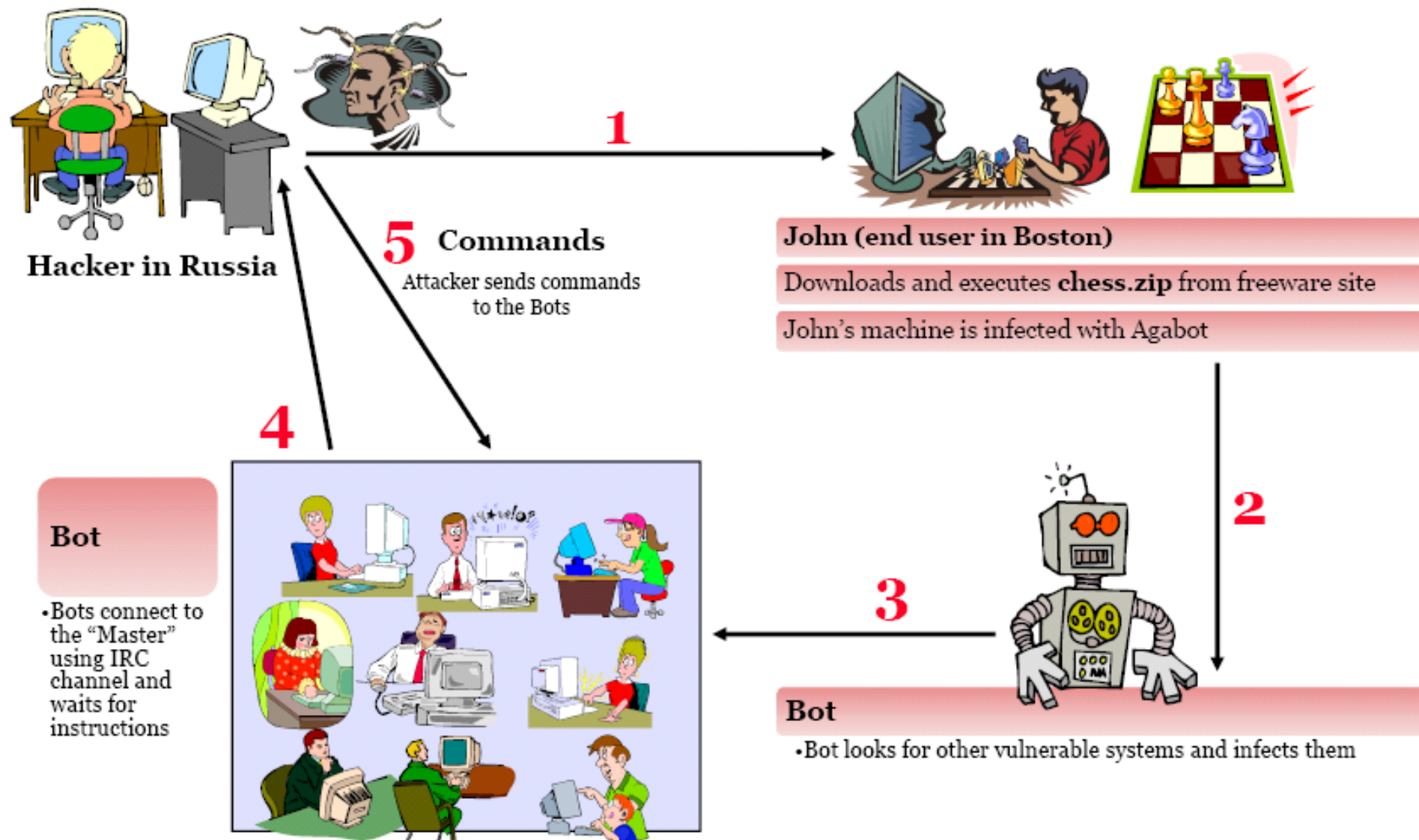


2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

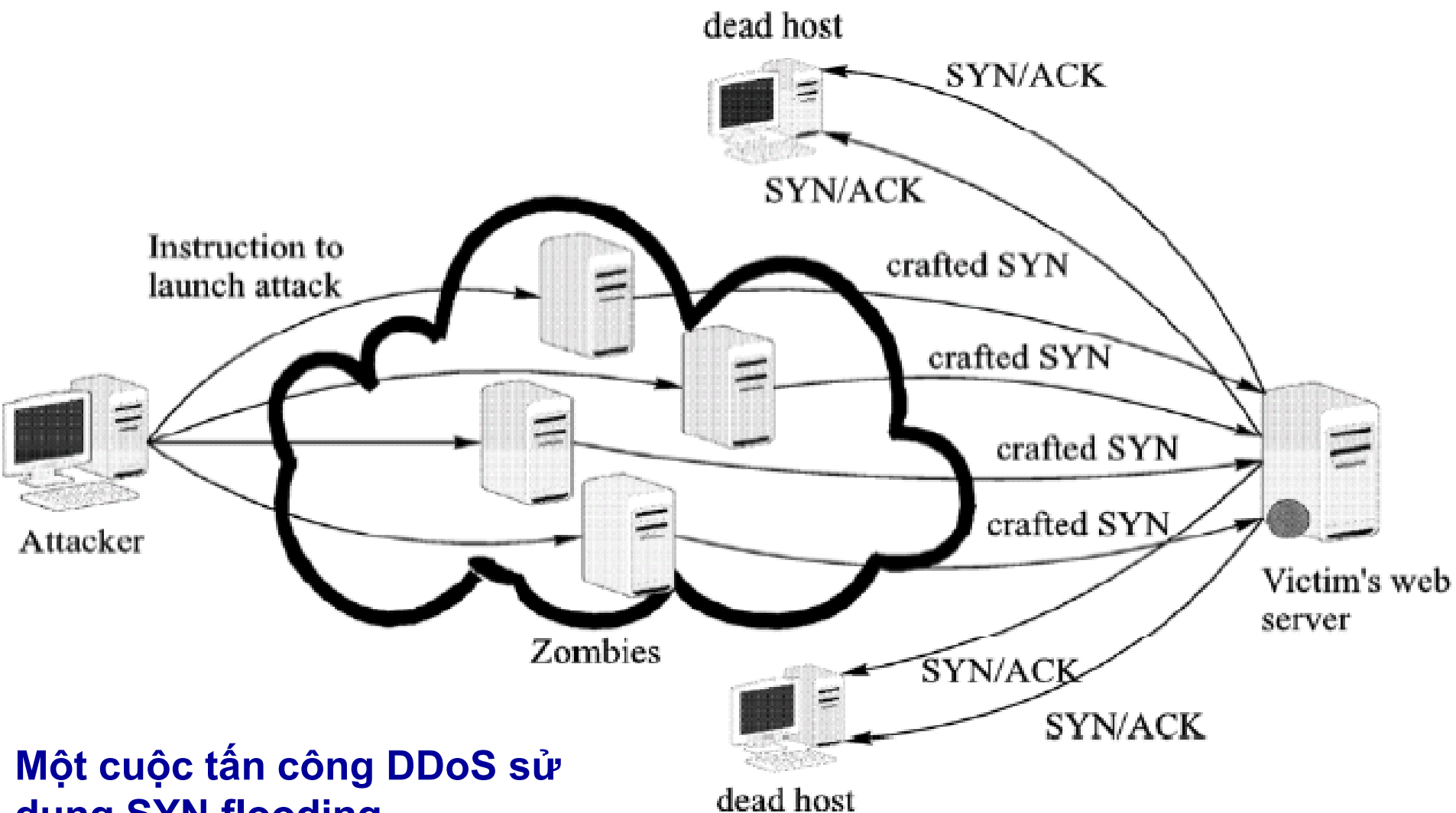
6. *Denial of Service Attacks*

- DDoS (Distributed DoS) có cơ chế hoạt động:
 - Attackers thường sử dụng Trojan để kiểm soát cùng lúc nhiều máy tính nối mạng.
 - Attacker cài đặt một phần mềm đặc biệt (phần mềm zombie) lên các máy tính này (máy tính zombie) để tạo ra một đội quân zombie (botnet) nhằm tấn công DoS sau này trên máy nạn nhân.
 - Phát hành một lệnh tấn công vào các máy tính zombie để khởi động một cuộc tấn công DoS trên cùng một mục tiêu (máy nạn nhân) cùng một lúc.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

Các phần mềm độc hại bao gồm:

- Virus,
- Worms,
- Trojan horses,
- Logic bombs,
- Backdoors
- Spyware.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ ***Virus***

- Là một phần mềm có thể sao chép chính nó. Nó không đứng một mình mà phải gắn vào một tập tin hoặc một chương trình khác.
- Khi một chương trình bị nhiễm virus máy tính được thực hiện hoặc một tập tin bị nhiễm được mở ra, loại virus chứa trong nó sẽ được thực thi.
- Khi thực hiện, virus có thể làm hại máy tính và sao chép chính nó để lây nhiễm sang máy khác trong hệ thống.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ ***Worms***

- Worm (sâu máy tính) là một loại mã độc tự nhân bản, có khả năng tự lây lan qua mạng mà không cần sự can thiệp của người dùng hay đính kèm vào tập tin khác.
- Mục tiêu của worm là lan truyền nhanh chóng, gây tắc nghẽn mạng, chiếm tài nguyên hệ thống hoặc phát tán thêm mã độc khác.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ ***Trojan horses:***

- Thường nguy trang mình kèm theo những chương trình ứng dụng thông thường và vô hại như trò chơi hoặc những công cụ miễn phí để người dùng tải về máy.
- Trojan không tự sinh sản như virus hay worm và chỉ thực hiện khi người dùng chạy chương trình có đính kèm Trojan.
- Chức năng chính của Trojan là điều khiển máy tính từ xa, ăn cắp thông tin của nạn nhân hoặc làm nhiệm vụ backdoor.



2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ *Logic bombs*

- Logic Bombs: là một đoạn mã độc được cài sẵn trong hệ thống hoặc phần mềm, chỉ kích hoạt khi một điều kiện cụ thể xảy ra; ví dụ như một ngày nhất định, một hành động của người dùng, hoặc khi tập tin nào đó bị xóa.
- Khi kích hoạt, nó có thể gây hại như xóa dữ liệu, làm hỏng hệ thống, hoặc mở cửa cho tấn công khác.
- Ví dụ: Một nhân viên bất mãn cài bom logic vào hệ thống, để khi tài khoản của họ bị xóa, mã độc sẽ tự động xóa toàn bộ cơ sở dữ liệu công ty.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ ***Backdoors***

- Backdoors là những đoạn chương trình bí mật thường được đính kèm vào những chương trình khác nhằm giúp kẻ tấn công sau khi đã xâm nhập được vào hệ thống mở sẵn những lối vào (cổng hậu)..
- Khi được chạy trên máy nạn nhân, Backdoors sẽ thường trực trong bộ nhớ, mở một port (mặc định hoặc do kẻ tấn công quy định) giúp kẻ tấn công dễ dàng đột nhập vào máy nạn nhân thông qua port này.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ ***Spywares***

- Spyware là một loại phần mềm tự cài đặt chính nó trên máy tính của người dùng. Spyware thường được sử dụng để theo dõi xem người dùng làm gì và quấy rối họ với những thông điệp thương mại xuất hiện trong những cửa sổ popup.
- Thường gồm các loại Browser hijacking và Zombieware.

2. Các kỹ thuật tấn công phổ biến và cơ chế phòng thủ

7. *Malicious Software*

■ ***Spywares***

- Browser Hijacking: là một kỹ thuật có thể thay đổi các thiết lập của trình duyệt của người dùng. Nó có thể thay thế Website mặc định của người dùng với một trang web khác được lựa chọn bởi kẻ tấn công. Hoặc nó có thể ngăn chặn người dùng truy cập vào các Websites họ muốn đến thăm.
- Zombieware: là phần mềm có trên máy tính của người dùng và biến nó thành một zombie để khởi động các cuộc tấn công DDoS hoặc thực hiện các hoạt động có hại như gửi thư rác hoặc phát tán virus.

3. Lý lịch của những kẻ tấn công

■ Các attacker có thể là:

- Black-hat hackers
- Script kiddies
- Cyber spies
- Vicious employees
- Cyber terrorists



3. Lý lịch của những kẻ tấn công



■ Black-hat hackers

- Hackers là những người có tri thức đặc biệt về hệ thống máy tính. Họ quan tâm đến những chi tiết tinh tế của phần mềm, giải thuật, mạng máy tính và cấu hình hệ thống. Họ là một nhóm người ưu tú, năng động, được đào tạo tốt.
- Tùy theo mục đích, hackers được chia thành hackers mũ đen, hackers mũ trắng và hackers mũ xám.

3. Lý lịch của những kẻ tấn công



■ Script kiddies

- Là những người sử dụng các script hoặc các chương trình được phát triển bởi các hacker mũ đen (những công cụ hack) để tấn công các máy tính và gây thiệt hại cho người khác.
- Script kiddies chỉ biết sử dụng công cụ hack để tấn công các mục tiêu chứ không hiểu cách thức hoạt động và cũng không có khả năng viết ra những công cụ tương tự.
- Đa số Script kiddies chỉ là những thanh thiếu niên, không đủ nhận thức và chín chắn để hiểu hết những hậu quả do mình gây ra.

3. Lý lịch của những kẻ tấn công

■ Cyber spies

- Cyber spies (gián điệp mạng) là những cá nhân hoặc tổ chức sử dụng kỹ thuật tấn công mạng để thu thập thông tin bí mật từ các chính phủ, công ty, hoặc tổ chức khác mà không được phép.
- Mục tiêu: tình báo, chính trị, quân sự hoặc kinh tế. Thường hoạt động ẩn danh, có tổ chức và được tài trợ (thường là bởi quốc gia hoặc tập đoàn lớn).
- Kỹ thuật sử dụng: phishing, malware, trojan, APT (Advanced Persistent Threat), khai thác lỗ hổng phần mềm...



3. Lý lịch của những kẻ tấn công



■ Vicious employees (nhân viên độc hại hoặc nhân viên ác ý)

- Là những người trong nội bộ tổ chức (đang làm việc hoặc đã nghỉ việc) cố tình gây hại cho hệ thống, dữ liệu hoặc danh tiếng của công ty.
- Đặc điểm: Họ có quyền truy cập hợp pháp vào hệ thống, vì vậy rất khó phát hiện và ngăn chặn. Động cơ thường là trả thù, tức giận, tham lợi, hoặc bị lôi kéo bởi đối thủ.

3. Lý lịch của những kẻ tấn công

■ Vicious employees (nhân viên độc hại hoặc nhân viên ác ý)

– Hành vi có thể bao gồm:

- Xóa hoặc đánh cắp dữ liệu quan trọng.
- Cài logic bomb hoặc phần mềm độc hại.
- Rò rỉ thông tin nội bộ cho bên thứ ba.
- Làm gián đoạn hoạt động hệ thống.

– Cách phòng chống:

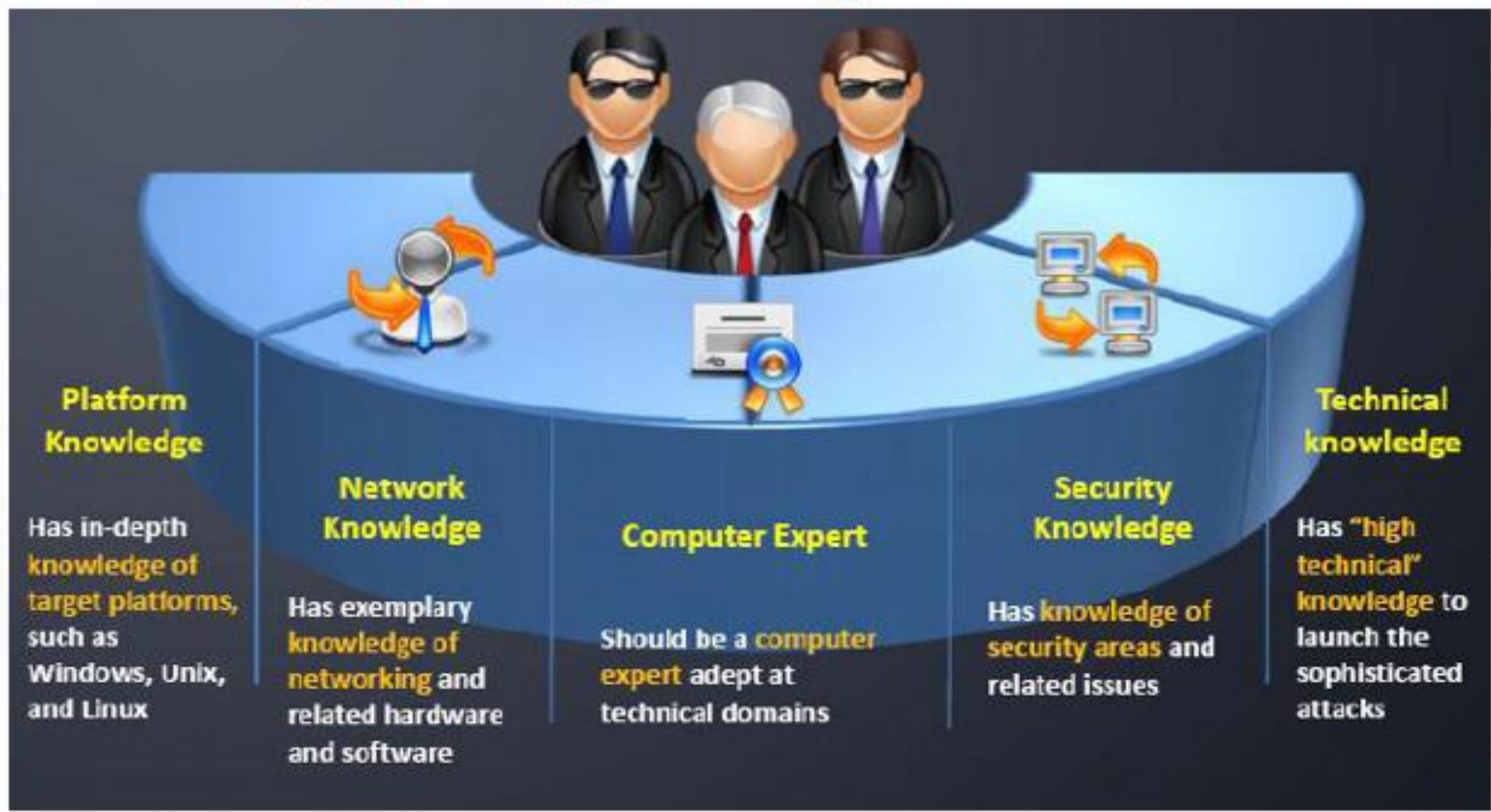
- Áp dụng nguyên tắc phân quyền tối thiểu (Least Privilege).
- Theo dõi và ghi log hoạt động người dùng.
- Thu hồi ngay quyền truy cập khi nhân viên nghỉ việc.



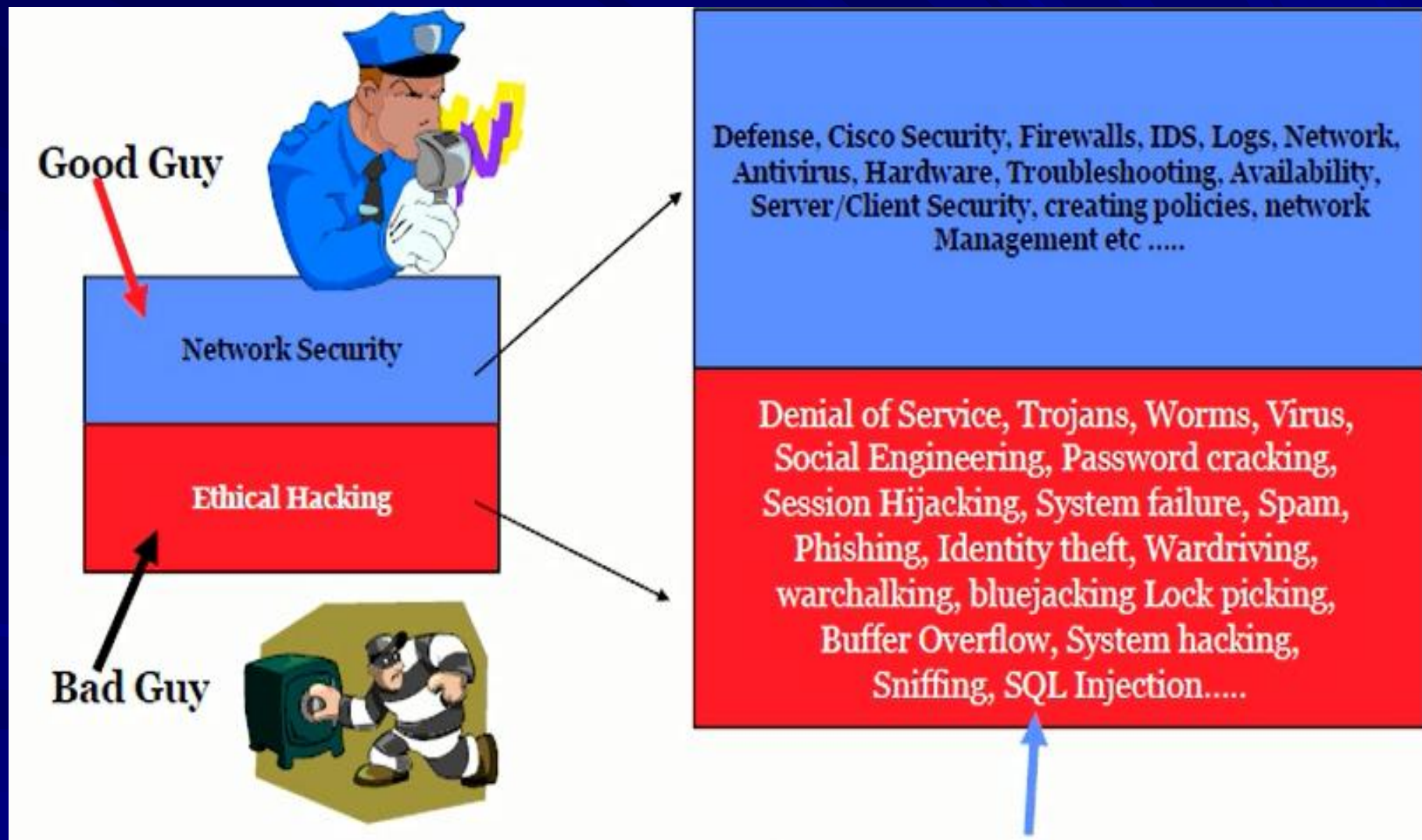
- Là những cá nhân hoặc tổ chức sử dụng tấn công mạng để gây ra hoảng loạn, phá hoại, hoặc làm tê liệt các hệ thống quan trọng nhằm phục vụ mục đích chính trị, tôn giáo, hoặc tư tưởng cực đoan.
- Mục tiêu: gây thiệt hại lớn, gieo sợ hãi, hoặc làm mất ổn định xã hội.
- Đối tượng tấn công: hạ tầng quan trọng như điện, nước, giao thông, y tế, tài chính, hoặc chính phủ.
- Hành vi thường thấy: Tấn công website chính phủ hoặc tổ chức quốc tế. Gây gián đoạn dịch vụ (DDoS, ransomware). Phá hoại hoặc thay đổi dữ liệu nhạy cảm.
- Ví dụ: Nhóm khủng bố mạng tấn công hệ thống điện Ukraine (2015) khiến hàng trăm nghìn người mất điện.

3. Lý lịch của những kẻ tấn công

Những kỹ năng của một Ethical Hacker



3. Lý lịch của những kẻ tấn công



3. Lý lịch của những kẻ tấn công Hành động của Hacker



3. Lý lịch của những kẻ tấn công

Hành động của Hacker

Phase 1 - Reconnaissance



Reconnaissance refers to the preparatory phase where an **attacker seeks to gather information** about a target prior to launching an attack



Could be the future point of return, noted for ease of entry for an attack when more about the **target is known on a broad scale**



Reconnaissance target range may include the **target organization's clients**, employees, operations, network, and systems

1

2

3

3. Lý lịch của những kẻ tấn công

Hành động của Hacker

Phase 1 - **Reconnaissance**

Reconnaissance Types

Passive Reconnaissance

- Passive reconnaissance involves acquiring information without directly interacting with the target
- For example, searching public records or news releases

Active Reconnaissance

- Active reconnaissance involves interacting with the target directly by any means
- For example, telephone calls to the help desk or technical department



3. Lý lịch của những kẻ tấn công Hành động của Hacker

Collect Network Information

- Domain name
- Internal domain names
- Network blocks
- IP addresses of the reachable systems
- Rogue websites/private websites
- TCP and UDP services running
- Access control mechanisms and ACL's
- Networking protocols
- VPN Points
- IDSes running
- Analog/digital telephone numbers
- Authentication mechanisms
- System enumeration

Collect System Information

- User and group names
- System banners
- Routing tables
- SNMP information
- System architecture
- Remote system type
- System names
- Passwords



Collect Organization's Information

- Employee details
- Organization's website
- Company directory
- Location details
- Address and phone numbers
- Comments in HTML source code
- Security policies implemented
- Web server links relevant to the organization
- Background of the organization
- News articles
- Press releases

3. Lý lịch của những kẻ tấn công Hành động của Hacker

- 1 **Footprinting through Search Engines**
- 2 **Footprinting Using Advanced Google Hacking Techniques**
- 3 **Footprinting through Social Networking Sites**
- 4 **Website Footprinting**
- 5 **Email Footprinting**
- 6 **Competitive Intelligence**
- 7 **WHOIS Footprinting**
- 8 **DNS Footprinting**
- 9 **Network Footprinting**
- 10 **Footprinting through Social Engineering**

3. Lý lịch của những kẻ tấn công

Hành động của Hacker

Phase 2 - Scanning

Pre-Attack Phase

Scanning refers to the pre-attack phase when the attacker scans the network for specific information on the basis of information gathered during reconnaissance



Port Scanner

Scanning can include use of dialers, port scanners, network mapping, sweeping, vulnerability scanners, etc.



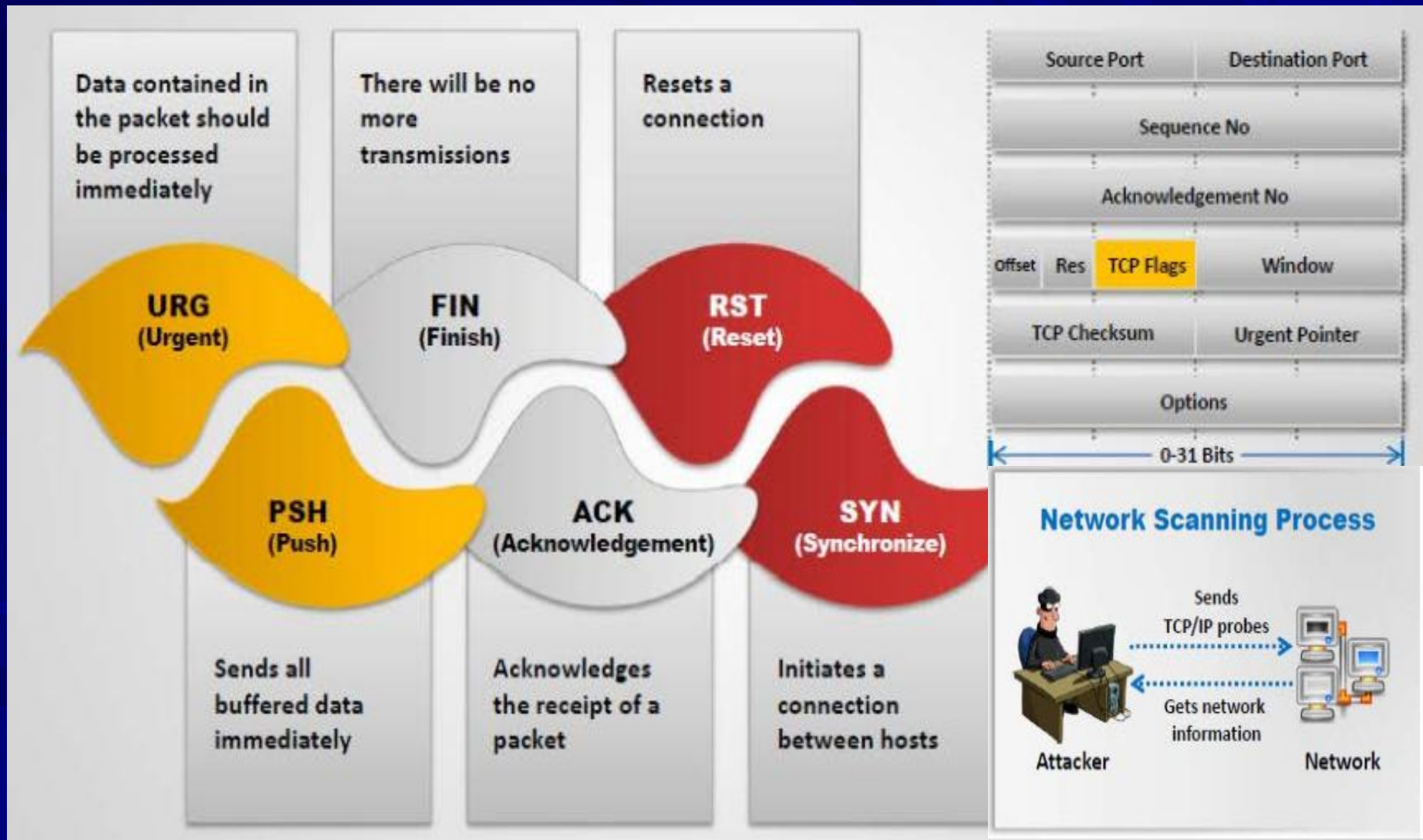
Extract Information

Attackers extract information such as computer names, IP address, and user accounts to launch attack

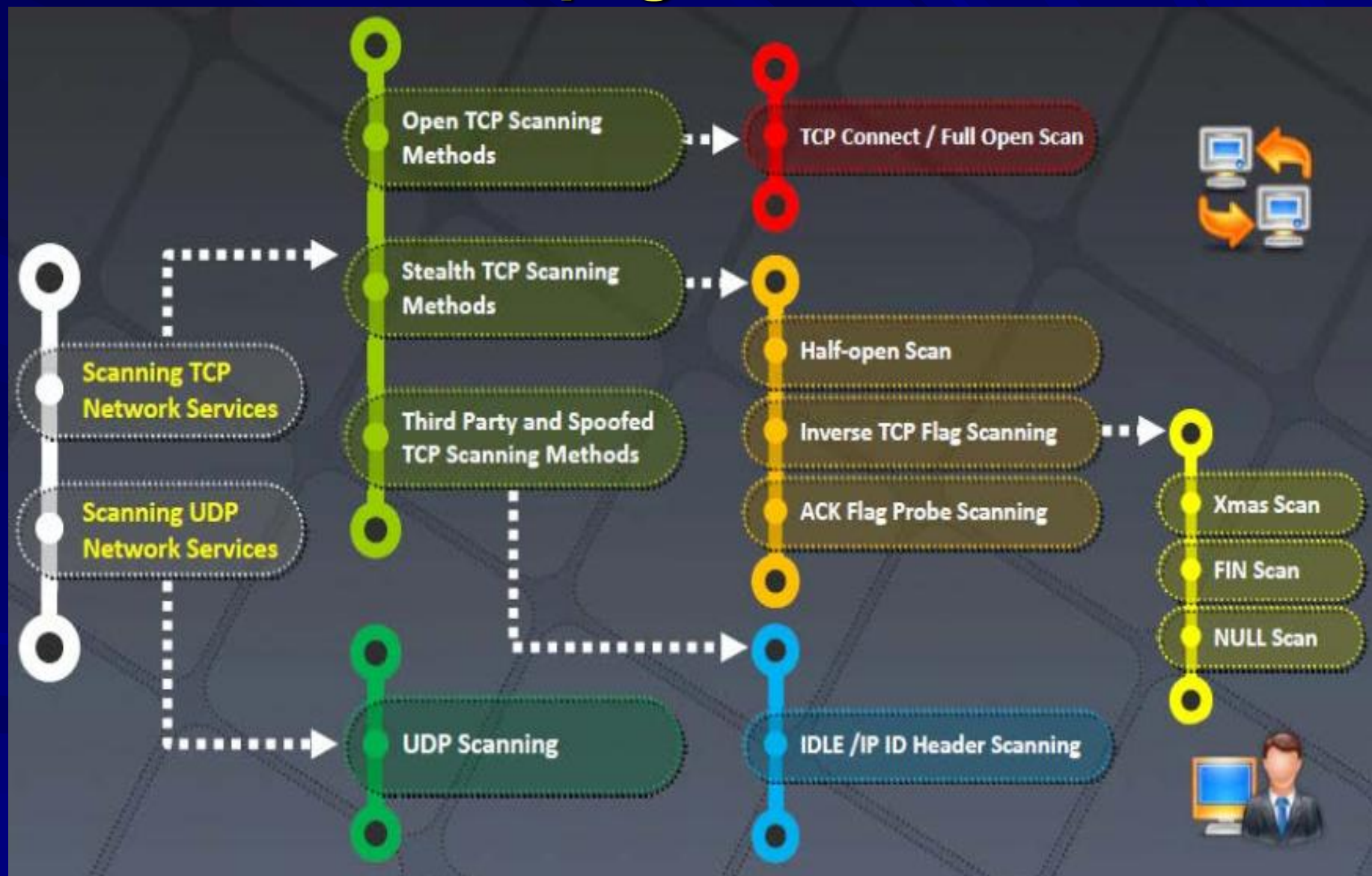


3. Lý lịch của những kẻ tấn công

Hành động của Hacker



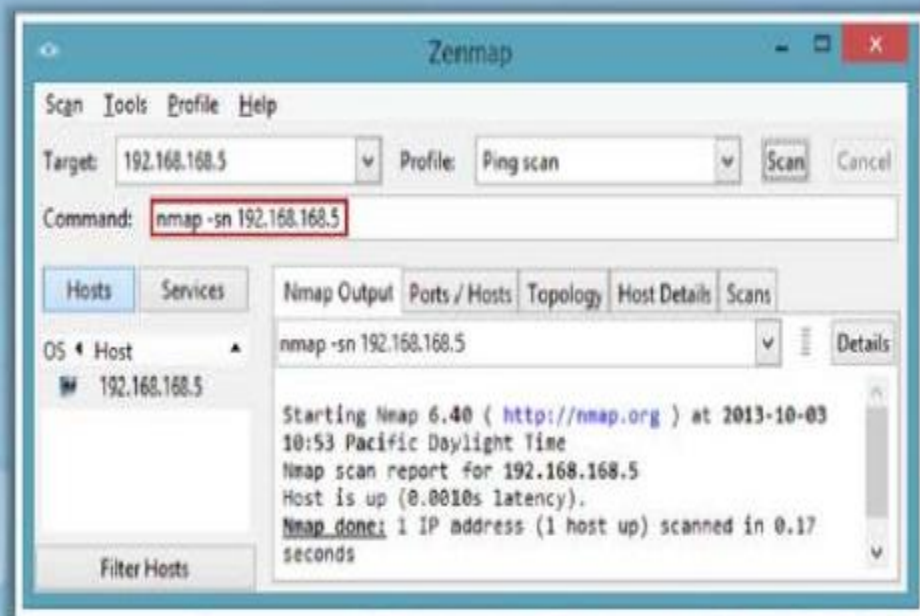
3. Lý lịch của những kẻ tấn công Hành động của Hacker



3. Lý lịch của những kẻ tấn công Hành động của Hacker

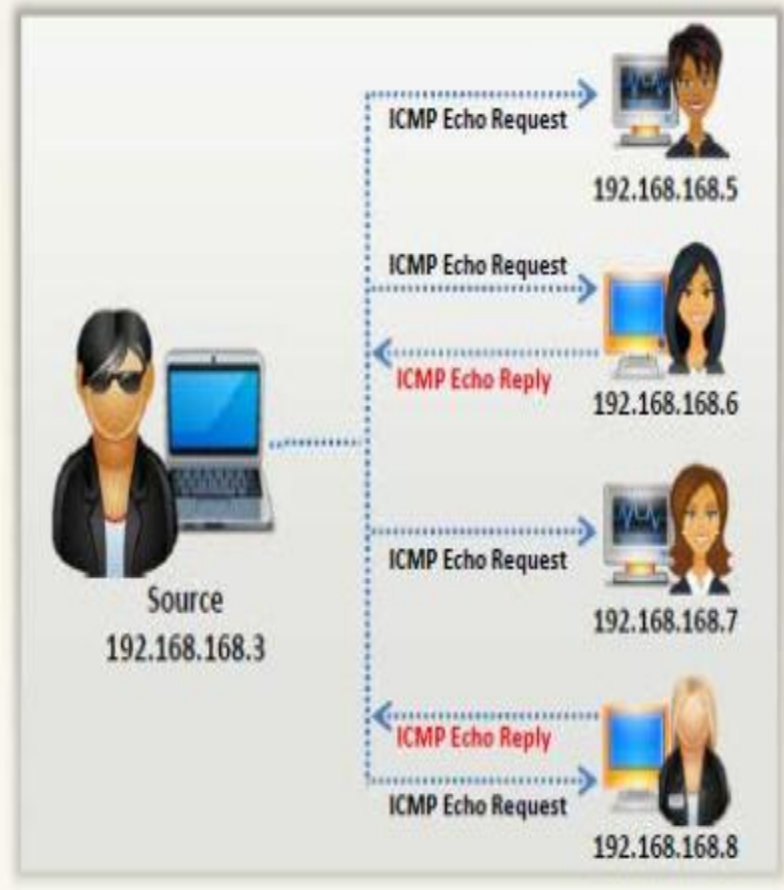
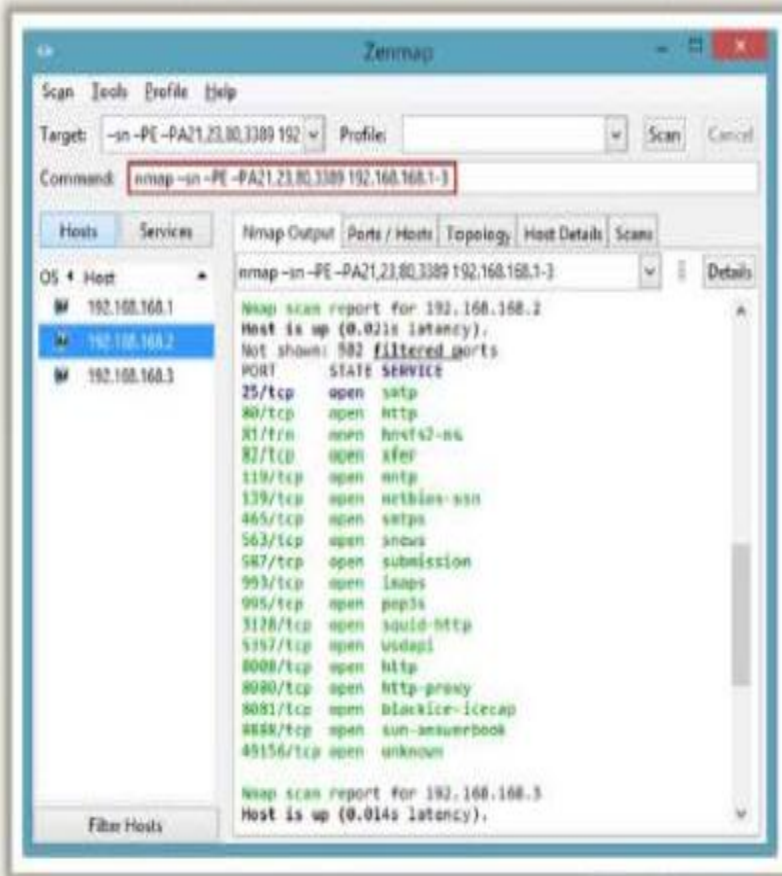


**The ping scan output
using Nmap:**



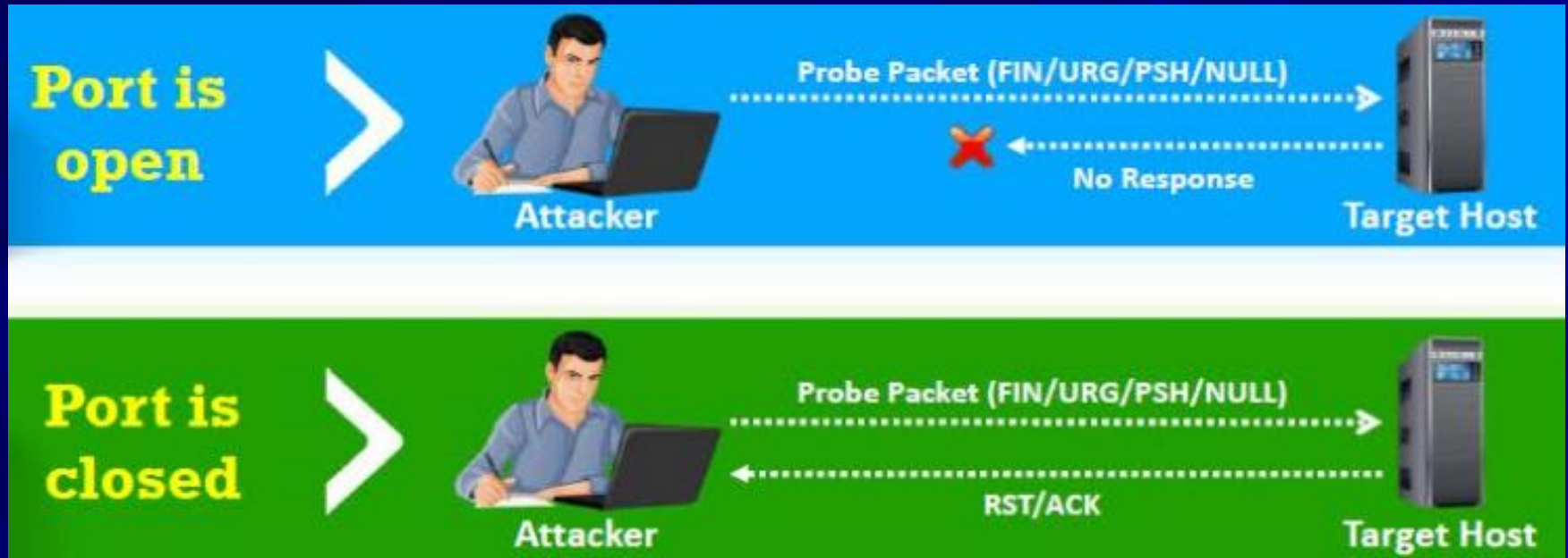
3. Lý lịch của những kẻ tấn công Hành động của Hacker

The ping sweep output using Nmap



3. Lý lịch của những kẻ tấn công

Hành động của Hacker



3. Lý lịch của những kẻ tấn công Hành động của Hacker

Umit Network Scanner



Fing



IP Network Scanner



3. Lý lịch của những kẻ tấn công Hành động của Hacker

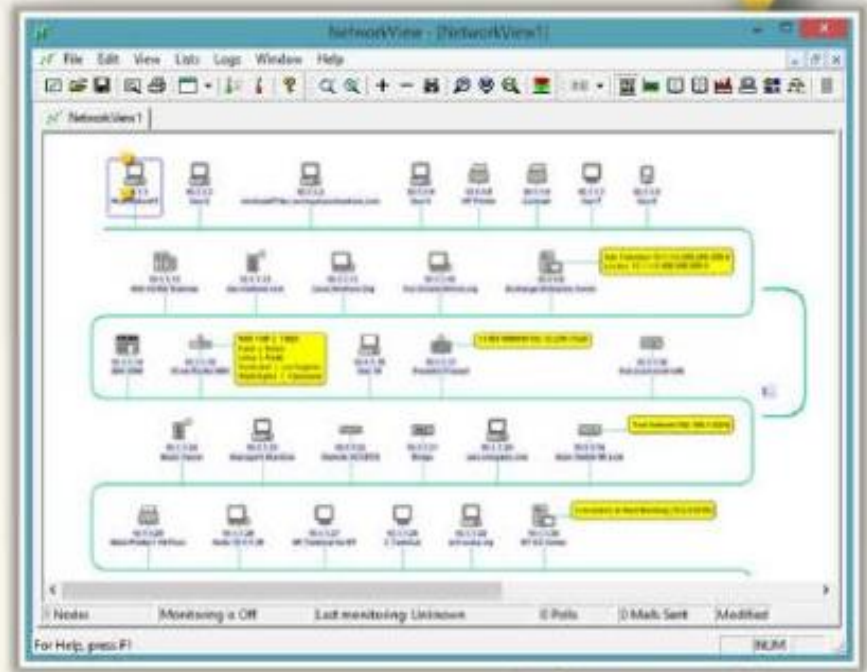
OpManager

OpManager is a network monitoring software that offers advanced **fault and performance management** functionality across critical **IT resources** such as routers, WAN links, switches, firewalls, VoIP call paths, physical servers, etc.



NetworkView

- NetworkView is a **network discovery and management** tool for Windows
- Discover TCP/IP nodes and routes** using DNS, SNMP, ports, NetBIOS, and WMI



3. Lý lịch của những kẻ tấn công

Hành động của Hacker

Phase 3 – Gaining Access

Gaining access refers to the point where the attacker obtains access to the operating system or applications on the computer or network

The attacker can gain access at the operating system level, application level, or network level

The attacker can escalate privileges to obtain complete control of the system. In the process, intermediate systems that are connected to it are also compromised

Examples include password cracking, buffer overflows, denial of service, session hijacking, etc.



3. Lý lịch của những kẻ tấn công Hành động của Hacker

Phase 4 – Maintaining Access



Maintaining access refers to the phase when the attacker tries to retain his or her ownership of the system

Attackers may prevent the system from being owned by other attackers by securing their exclusive access with Backdoors, RootKits, or Trojans



Attackers use the compromised system to launch further attacks

Attackers can upload, download, or manipulate data, applications, and configurations on the owned system



3. Lý lịch của những kẻ tấn công

Hành động của Hacker

Phase 5 – Covering Tracks

Covering tracks refers to the activities carried out by an attacker to hide malicious acts



The attacker's intentions include: Continuing access to the victim's system, remaining unnoticed and uncaught, deleting evidence that might lead to his prosecution



The attacker overwrites the server, system, and application logs to avoid suspicion



Attackers always cover tracks to hide their identity

3. Lý lịch của những kẻ tấn công Hành động của Hacker

Hacking-Stage	Goal	Technique/Exploit Used
 G aining Access	To bypass access controls to gain access to the system	Password cracking, social engineering
 E scalating Privileges	To acquire the rights of another user or an admin	Exploiting known system vulnerabilities
 E xecuting Applications	To create and maintain remote access to the system	Trojans, spywares, backdoors, keyloggers
 H iding Files	To hide attackers malicious activities and data theft	Rootkits, steganography
 C overing Tracks	To hide the evidence of compromise	Clearing logs

4. Mô hình bảo mật cơ bản

■ Mô hình bảo mật cơ bản gồm 4 thành phần:

– Hệ thống mã hoá (Cryptosystem):

- Sử dụng mật mã và các giao thức bảo mật để bảo vệ dữ liệu.
- Các giao thức bảo mật bao gồm các giao thức mã hoá, các giao thức chứng thực, các giao thức quản lý khoá.

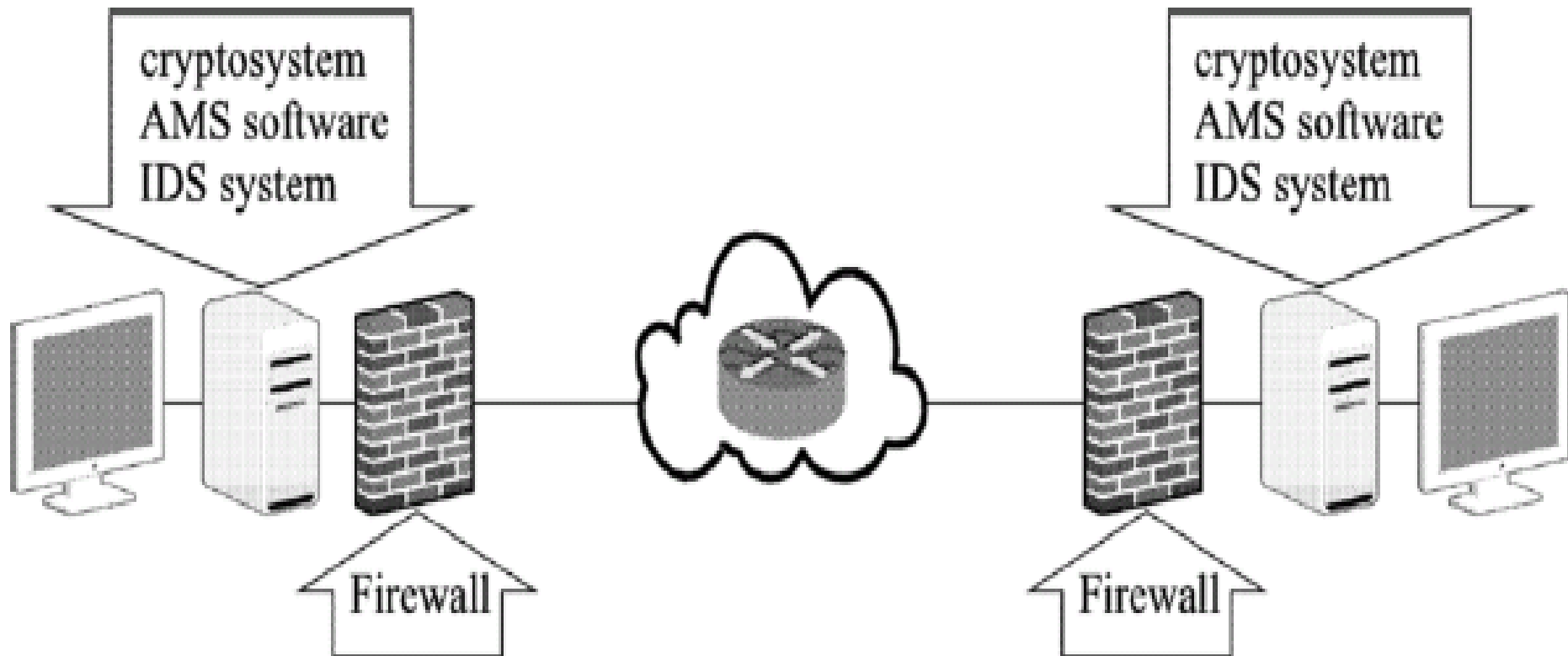
– Tường lửa (Firewalls):

- Là những gói phần mềm đặc biệt cài trên máy tính hoặc thiết bị mạng để kiểm tra các gói tin đi vào và đi ra trên mạng.

4. Mô hình bảo mật cơ bản

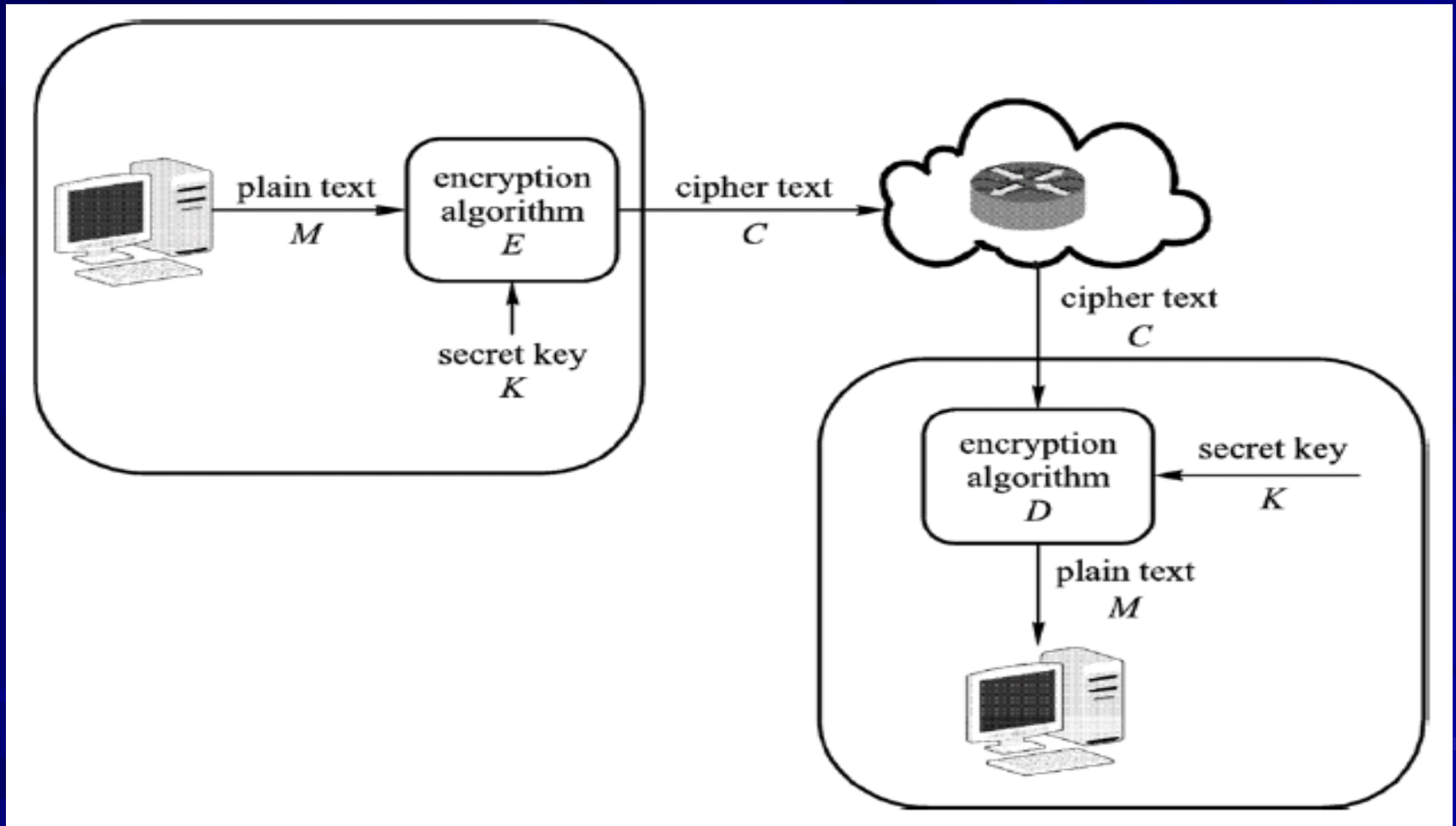
- Mô hình bảo mật cơ bản gồm 4 thành phần:
 - **Hệ thống phần mềm chống độc hại** (Anti-Malicious System software – AMS software): quét các thư mục hệ thống, tập tin, registry, sau đó nhận diện, cách ly hoặc xóa các mã độc hại.
 - **Hệ thống tìm kiếm xâm nhập** (Intrusion Detection System – IDS): giám sát việc đăng nhập vào hệ thống và hành vi của người dùng, phân tích file log để nhận diện và đưa ra cảnh báo khi phát hiện có sự xâm nhập.

4. Mô hình bảo mật cơ bản



Bốn thành phần của mô hình bảo mật cơ bản

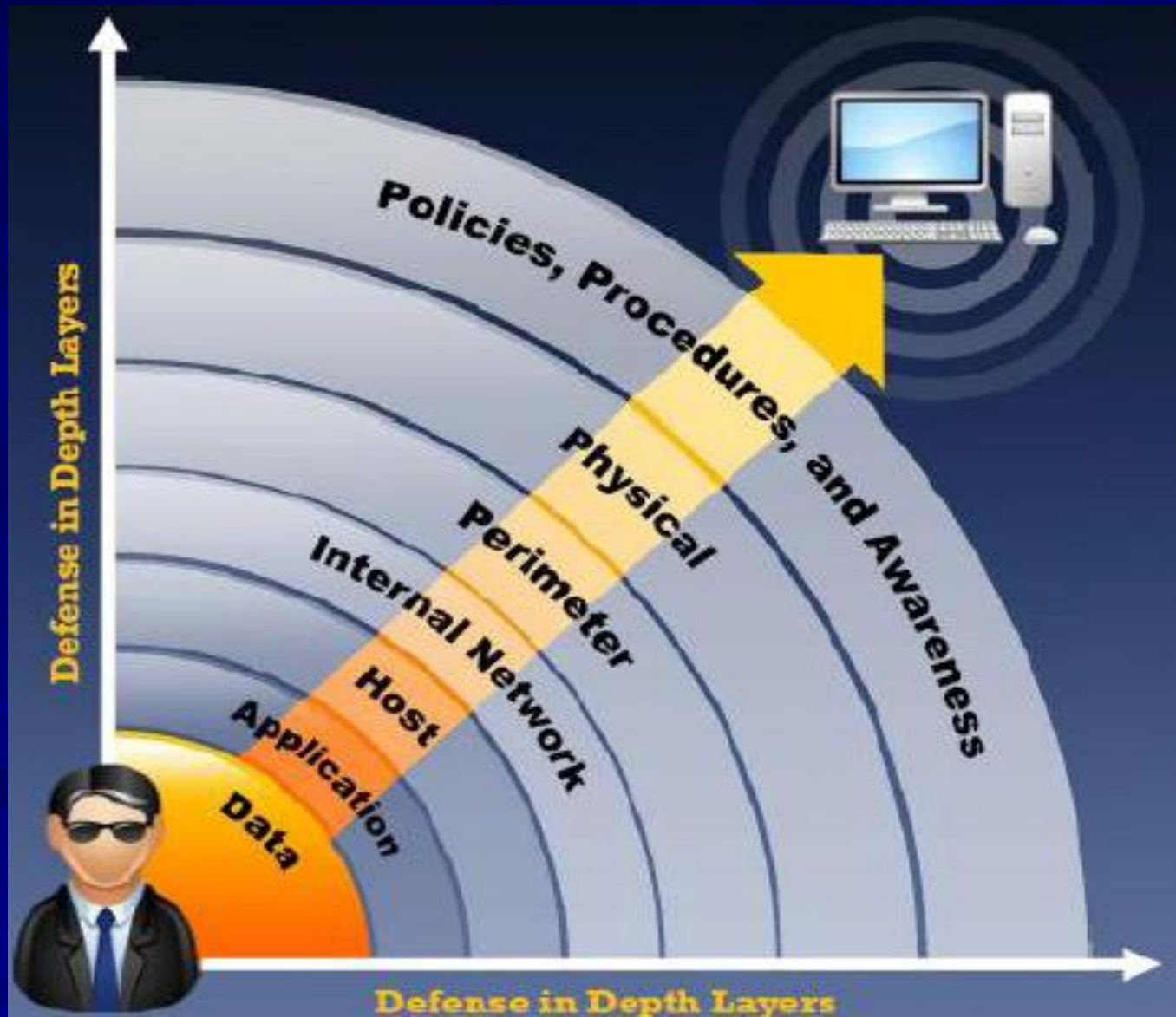
4. Mô hình bảo mật cơ bản



Mô hình mạng của hệ thống mã hoá

4. Mô hình bảo mật cơ bản

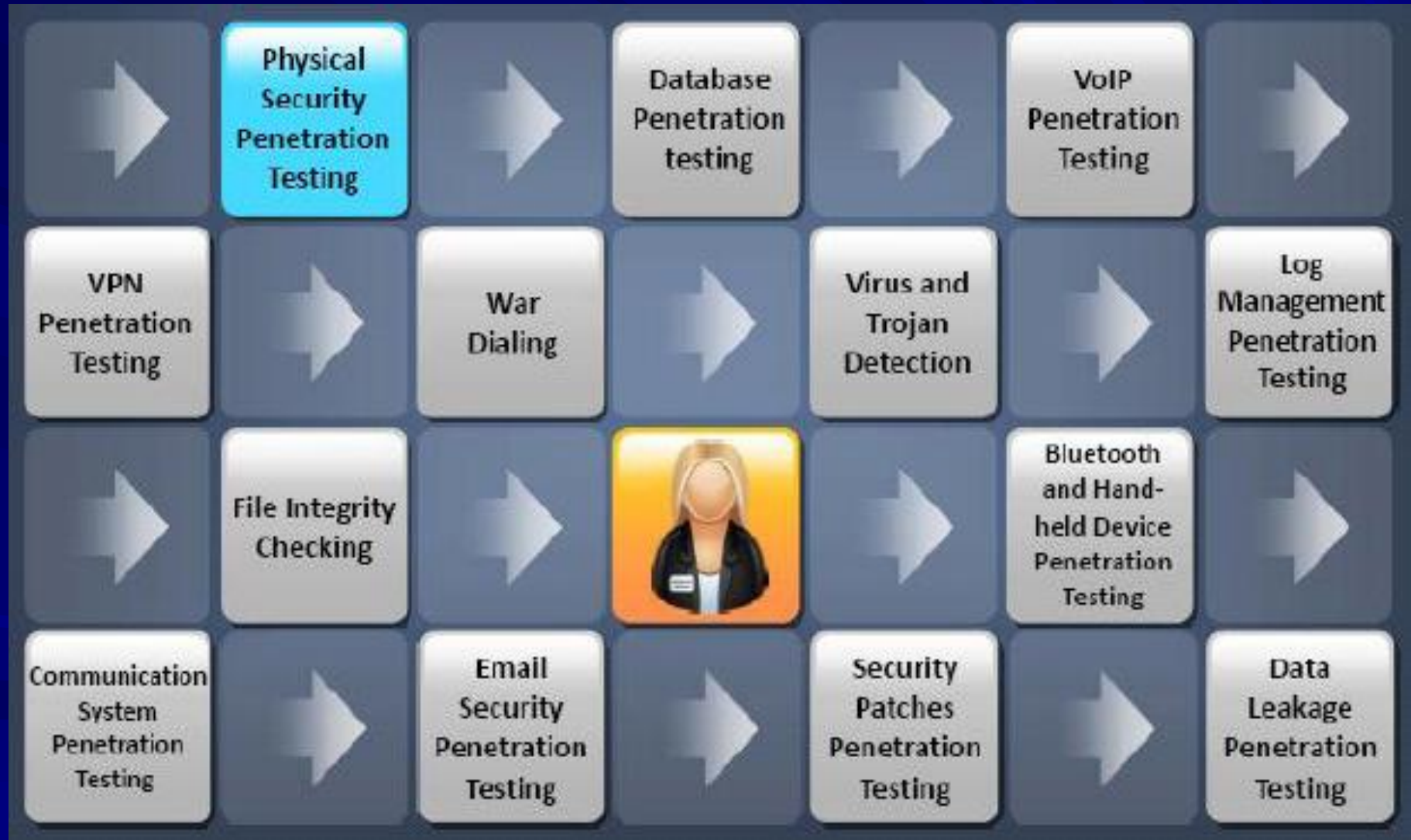
Phương thức phòng thủ



4. Mô hình bảo mật cơ bản Kiểm tra hệ thống



4. Mô hình bảo mật cơ bản Kiểm tra hệ thống



5. Bài tập

1. Phân tích hoạt động của mô hình bảo mật theo chiều sâu.
2. Lập bảng tổng hợp các kỹ thuật tấn công cơ bản (Tên gọi, cơ chế hoạt động, công cụ sử dụng, kết quả đạt được, biện pháp phòng chống...).

Đặt tên file: Bài tập 1 - Họ tên_mssv.doc